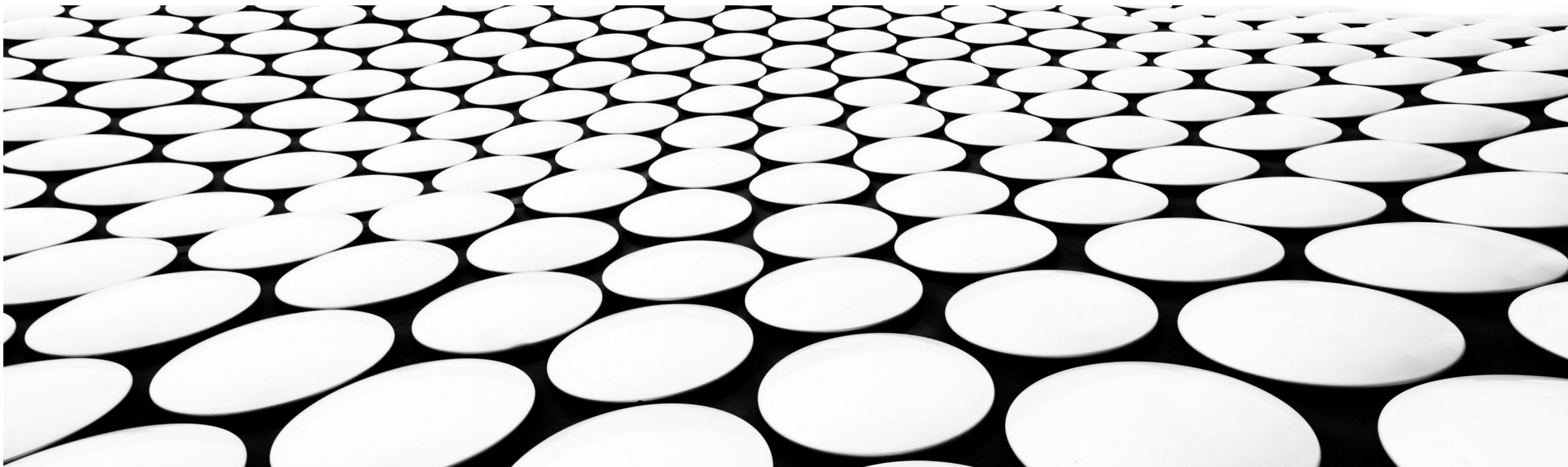


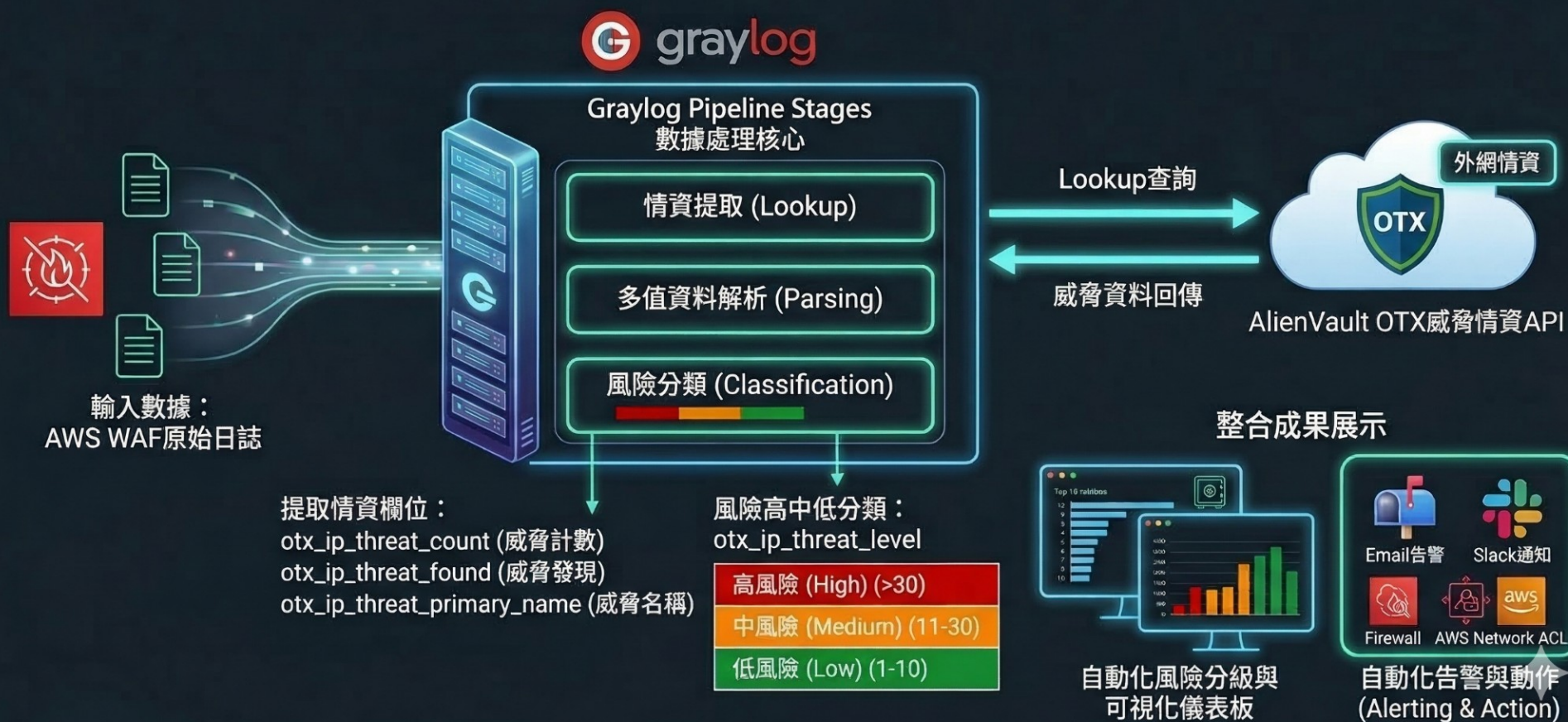
WAF 外部資源整合防禦優化

運用社群力量：開源 OTX 與 C2 偵測

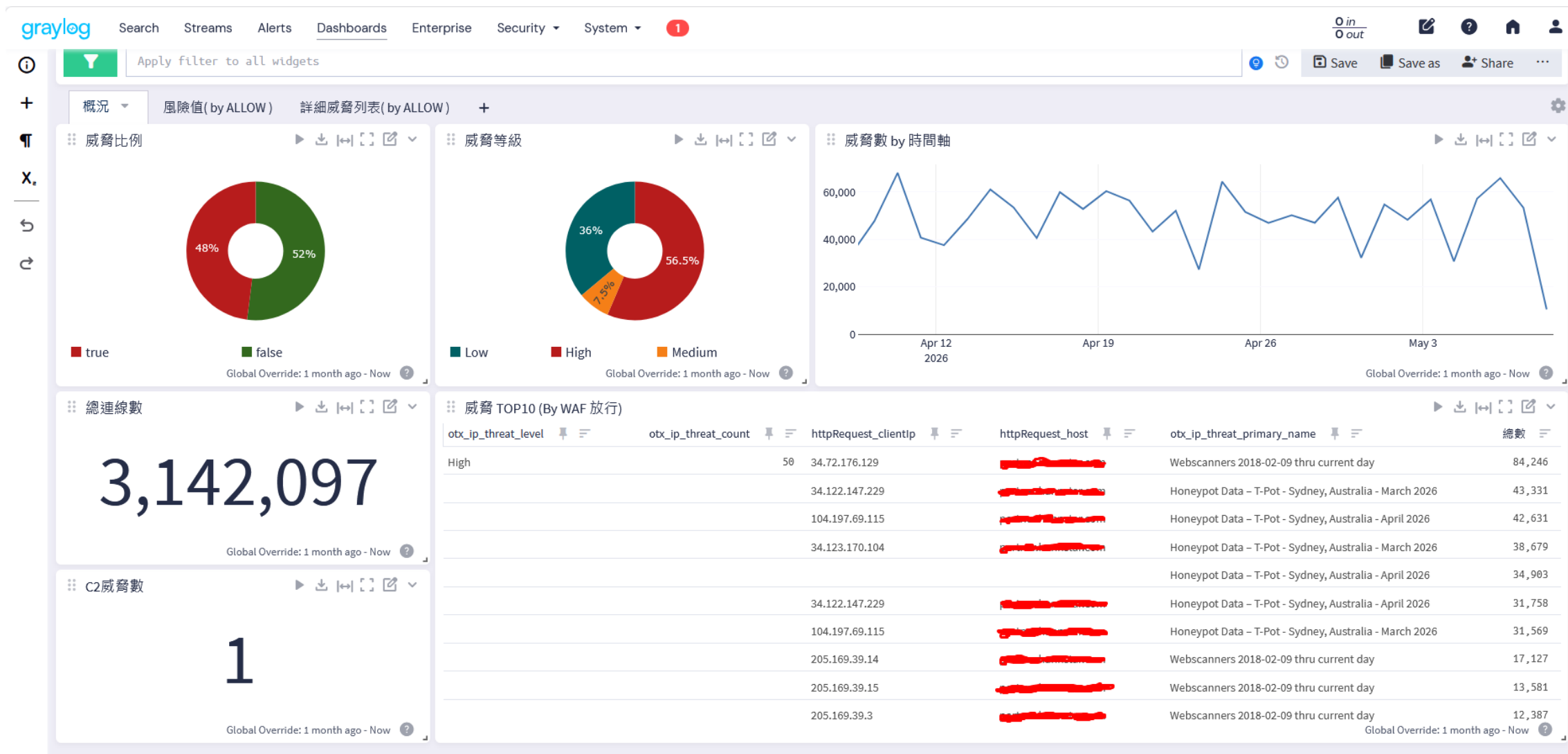


GRAYLOG 整合 ALIENVAULT OTX 情資

Graylog與AlienVault OTX資安情資自動化整合



GRAYLOG - OTX DASHBOARD 展示



TEAMS 定時推送告警

 ELK-ALERT 上午 07:06

新增

[Tokyo Region] 定時掃描結果概覽

[Tokyo Region] WAF 每小時 Action:ALLOW - Top10 報告

告警等級：警告 ⚡⚡⚡⚡⚡

🚩 來源國家：Germany, IP: 109.123.253.38, 數量: 3025

來源國家：United States, IP: 34.122.147.229, 數量: 165

來源國家：United States, IP: 34.223.183.208, 數量: 100

來源國家：United States, IP: 34.123.170.104, 數量: 99

來源國家：United States, IP: 104.197.69.115, 數量: 66

來源國家：United States, IP: 205.169.39.4, 數量: 66

來源國家：United States, IP: 205.169.39.5, 數量: 66

來源國家：United States, IP: 205.169.39.58, 數量: 66

來源國家：United States, IP: 205.169.39.6, 數量: 66

來源國家：United States, IP: 205.169.39.190, 數量: 56



 在對話中回覆

 ELK-ALERT 星期六 上午 11:15

新增

WAF ALLOW 行為告警 (15 分鐘內)

15分鐘內 AWS ALLOW 允許數量上限值

告警等級：警告 ⚡⚡⚡⚡⚡

目前數目：4851 > 警戒數目：2000

TOP3 連線

IP: 117.31.27.134, 數目：752, 國家：China

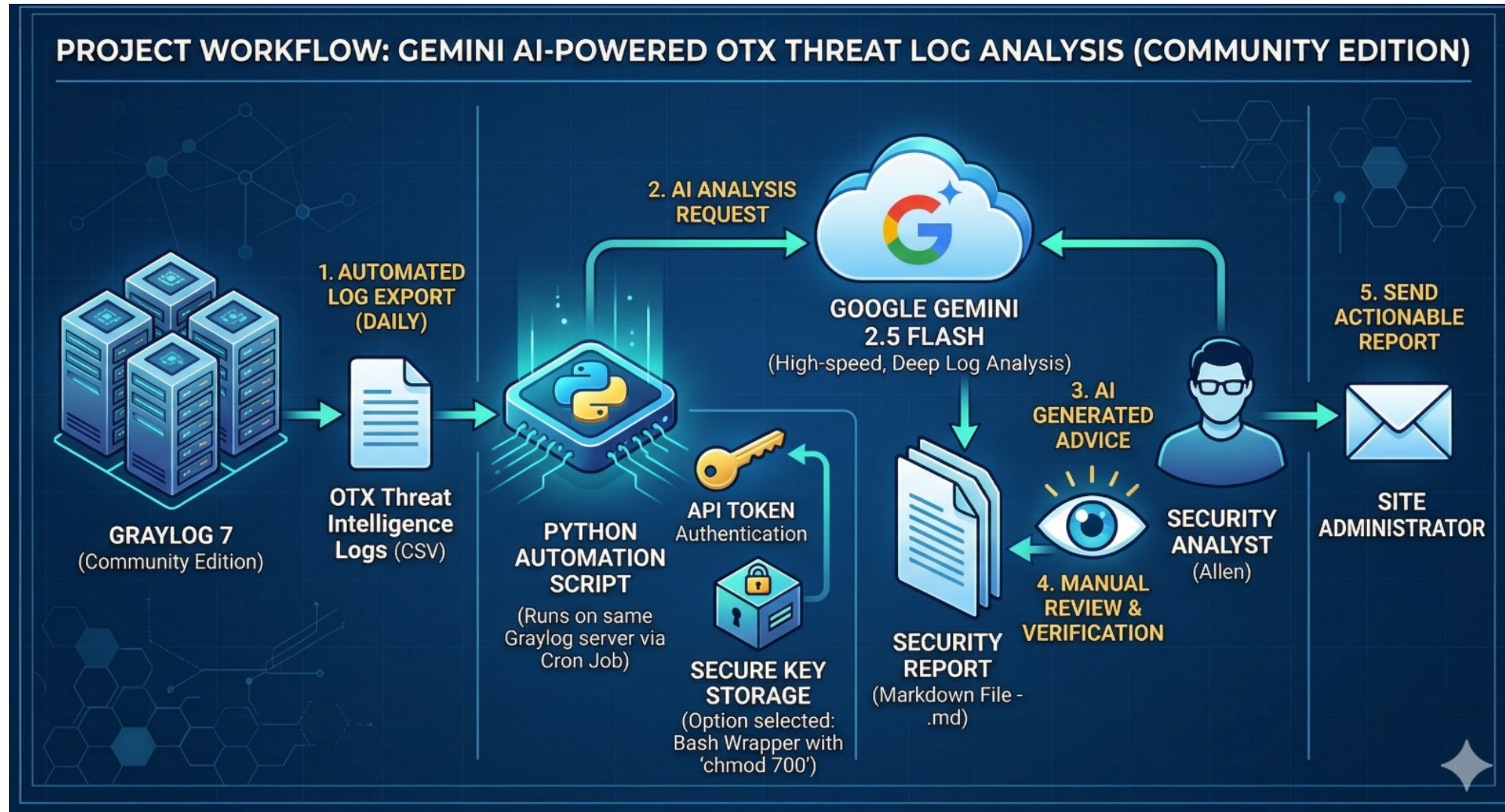
IP: 116.171.32.3, 數目：497, 國家：China

IP: 123.171.18.152, 數目：466, 國家：China



 在對話中回覆

GEMINI AI 整合情資判讀



GRAYLOG 威脅情資去識別化

graylog Search Streams Alerts Dashboards Enterprise Security System 1

0 in 0 out

Dashboards > OTX ☆

From: 1 month ago Until: Now

Apply filter to all widgets

Save Save as Share

Not updating

概況 風險值 (by ALLOW) 詳細威脅列表 (by ALLOW) +

Untitled Message Table

timestamp	otx_ip_threat_level	otx_ip_threat_count	httpRequest_clientip	httpRequest_host	httpRequest_uri	otx_ip_threat_primary_name
2026-05-08 15:06:18.773	High	50	205.169.39.21	[REDACTED]	/css/FontAwesome/css/all.css	DugganUSA Threat Intel 2026-05-08 #1
2026-05-08 15:06:18.773	High	50	205.169.39.21	[REDACTED]	/Scripts/jquery-3.7.1.min.js	DugganUSA Threat Intel 2026-05-08 #1
2026-05-08 15:06:18.772	High	50	205.169.39.21	[REDACTED]	/WebResource.axd	DugganUSA Threat Intel 2026-05-08 #1
2026-05-08 15:06:18.772	High	50	205.169.39.21	[REDACTED]	/Scripts/bootstrap.min.js	DugganUSA Threat Intel 2026-05-08 #1
2026-05-08 15:06:18.772	High	50	205.169.39.21	[REDACTED]	/css/Partner.css	DugganUSA Threat Intel 2026-05-08 #1
2026-05-08 15:06:18.772	High	50	205.169.39.21	[REDACTED]	/css/supplier/utility.css	DugganUSA Threat Intel 2026-05-08 #1
2026-05-08 15:06:18.772	High	50	205.169.39.21	[REDACTED]	/css/supplier/main.css	DugganUSA Threat Intel 2026-05-08 #1
2026-05-08 15:06:18.772	High	50	205.169.39.21	[REDACTED]	/account/login.aspx	DugganUSA Threat Intel 2026-05-08 #1
2026-05-08 15:06:18.772	High	50	205.169.39.21	[REDACTED]	/css/supplier/footer.css	DugganUSA Threat Intel 2026-05-08 #1
2026-05-08 15:06:18.772	High	50	205.169.39.21	[REDACTED]	/Scripts/wow.js	DugganUSA Threat Intel 2026-05-08 #1
2026-05-08 15:06:18.772	High	50	205.169.39.21	[REDACTED]	/images/supplier/login_background2.png	DugganUSA Threat Intel 2026-05-08 #1
2026-05-08 15:06:18.772	High	50	205.169.39.21	[REDACTED]	/Scripts/moment.min.js	DugganUSA Threat Intel 2026-05-08 #1
2026-05-08 15:06:18.772	High	50	205.169.39.21	[REDACTED]	/images/srm/logo_hannsOffice_w.png	DugganUSA Threat Intel 2026-05-08 #1
2026-05-08 15:06:18.772	High	50	205.169.39.21	[REDACTED]	/Scripts/slick-slider/slick.min.js	DugganUSA Threat Intel 2026-05-08 #1
2026-05-08 15:06:18.772	High	50	205.169.39.21	[REDACTED]	/images/supplier/icon/icon-login.png	DugganUSA Threat Intel 2026-05-08 #1
2026-05-08 15:06:18.772	High	50	205.169.39.21	[REDACTED]	/Scripts/slick-slider/slick.css	DugganUSA Threat Intel 2026-05-08 #1
2026-05-08 15:06:18.772	High	50	205.169.39.21	[REDACTED]	/css/supplier/privacy.css	DugganUSA Threat Intel 2026-05-08 #1
2026-05-08 15:06:18.772	High	50	205.169.39.21	[REDACTED]	/WebResource.axd	DugganUSA Threat Intel 2026-05-08 #1
2026-05-08 15:06:18.772	High	50	205.169.39.21	[REDACTED]	/public/error	DugganUSA Threat Intel 2026-05-08 #1
2026-05-08 15:06:18.772	High	50	205.169.39.21	[REDACTED]	/css/FontAwesome/webfonts/fa-solid-900.woff2	DugganUSA Threat Intel 2026-05-08 #1

Global Override: 1 month ago - Now

將等級中級以上 Logs 整合成專屬 Dashboard 提供後續 Gemini AI 分析

GEMINI AI 判讀報告

基於以上分析，為貴公司管理團隊提出以下整體防護優化方案：

1. 提升威脅情報整合與自動化阻擋能力：

- **行動：** 建立更完善的威脅情報自動化流程。將 OTX、DugganUSA、VoidTrap 等多個威脅情報來源的數據，自動整合並更新至 AWS WAF 的 IP 信譽列表和自定義規則中。
- **優勢：** 減少人工處理威脅情報的時間，能更快地阻擋已知的惡意 IP，降低潛在攻擊的命中率。
- **AWS WAF 實施：** 利用 AWS WAF 的 IP Set 功能，定期自動更新 IP 阻擋列表。配置 Custom rule set，根據威脅等級設置不同的阻擋策略。

2. 強化 Web 應用程式防火牆 (WAF) 的配置與調優：

- **行動：**
 - **動態速率限制 (Rate-based rules)：** 為所有暴露於互聯網的關鍵域名（尤其是 **partner.hannstar.com** 和 **index_guard.php**）設定嚴格的 Rate-based rules，以防止暴力破解、掃描和 DoS 攻擊。
 - **精細化惡意流量偵測：** 部署並持續優化 AWS WAF 的 Managed Rules (如 OWASP Top 10, Bot Control, SQL database rule group)，並根據日誌分析結果調整誤報 (False Positives)。
 - **後台管理入口保護：** 針對敏感後台管理頁面（如 **/manager/index_guard.php**），實施 IP 白名單限制，並考慮結合多因素驗證 (MFA) 或 VPN 訪問。
- **優勢：** 直接在邊緣阻擋惡意流量，減輕後端伺服器負擔，有效應對已知和常見的 Web 攻擊。
- **AWS WAF 實施：** 積極利用 AWS WAF 的地理位置限制 (Geo match rule) 來阻擋來自不必要地區的流量，配置 Web ACLs 並為各域名創建專屬規則組。

3. 落實縱深防禦策略，強化日誌分析與事件響應：

- **行動：**
 - **集中式日誌管理與分析：** 確保所有 AWS 資源（包括 WAF、ELB、EC2/ECS/EKS）的日誌都匯總至 Graylog（或 AWS CloudWatch Logs + OpenSearch），並建立關鍵事件的告警規則。
 - **定期安全演練與事件響應計劃更新：** 依據最新的威脅情報和攻擊趨勢，定期檢視和更新事件響應計劃 (Incident Response Plan)，並進行模擬演練，確保團隊能夠快速有效地應對安全事件。
 - **資產盤點與漏洞管理：** 建立完整的資產清單，並定期進行漏洞掃描和滲透測試，確保所有對外服務都處於安全狀態。
- **優勢：** 提升對異常活動的偵測能力，縮短事件響應時間，減少潛在損害。
- **AWS 實施：** 利用 AWS CloudTrail 追蹤 API 活動，CloudWatch Logs 匯總應用程式日誌，並可考慮與 AWS Security Hub 整合，統一安全告警。

b. **partner.hannstar.com**

• 攻擊行為分析：

- **Web 掃描器活動 (Webscanners 2018-02-09 thru current day)：** 與 partner.hannstar.com 類似，該域名也是 Web 掃描器的重點目標，特別是針對 **index_guard.php** 和 **validate.js** 等常見腳本。
- **Cloudflare Honeypot Web Attack Hosts:** 此域名也頻繁出現在 Cloudflare Honeypot 的日誌中，表明有被惡意利用或探測的風險。
- **Honeypot Data – T-Pot - Sydney, Australia - March/April 2026:** 顯示有來自惡意掃描器或自動化攻擊工具的流量，可能試圖利用前端資源（如 CSS、JS、woff2 檔案）進行攻擊。
- **DugganUSA Threat Intel / VoidTrap Live Threat Feed:** 這些來源指出有來自已知惡意 IP 的訪問，可能與特定惡意程式活動或滲透測試相關。

• 技術防禦建議：

1. 限制對後台管理頁面及敏感腳本的訪問權限：

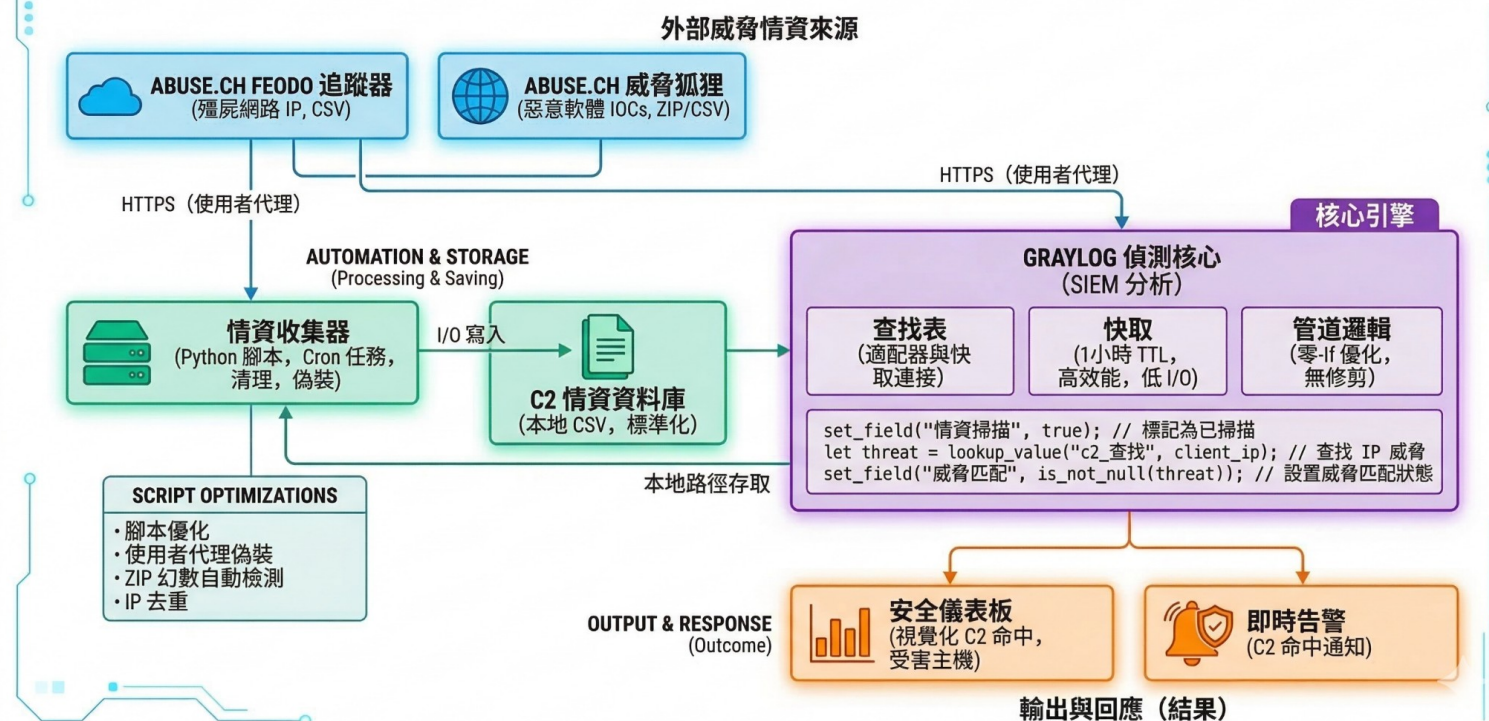
- 優先保護 **/manager/index_guard.php**、**/manager/index_supemp.php** 等後台管理頁面，實施 IP 白名單限制，只允許受信任的 IP 地址訪問。
- 針對 Javascript 和 CSS 等靜態資源，確保其權限設定正確，避免被用於惡意代碼注入或反射攻擊。

2. 利用 WAF 針對性阻擋高風險 URL 模式與簽名：

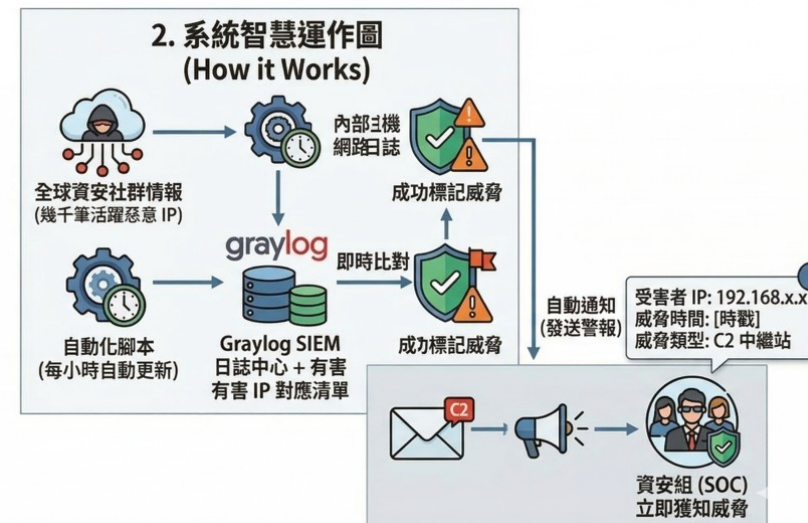
- 建立 WAF 規則，針對 URL 中包含可疑字串（如 **%3C/font**、**.php** 後接可疑參數）的請求進行阻擋，這可能指向 SQL 注入或命令注入嘗試。
- 定期更新 WAF 的惡意簽名庫，以識別和阻擋已知惡意腳本或惡意軟體下載嘗試。

GRAYLOG 整合 ABUSE_CH 判斷 C2 連線

C2 威脅情資偵測系統架構圖



2. 系統智慧運作圖 (How it Works)



GRAYLOG 偵測展示

